Security and architecture

Security and architecture

Software architecture is crucial for **DevSecOps** because it lays the foundation for integrating security, development, and operations in a seamless, scalable, and resilient manner.



Source: https://www.brilworks.com/blog/popular-architectures-for-software-development/

Application architecture considerations for DevSecOps:

- **Security by Design**
- **Scalability and Resilience**
- **Automation and CI/CD Integration**
- **Observability and Compliance**
- **Performance and Efficiency**

Source: https://blog.gitguardian.com/secure-by-design-software-in-devsecops

Copyright© 2025 PeopleCert International Ltd.

Security benefits of well-architected applications

- **Security by design:** security is integrated from the earliest stages of development, reducing vulnerabilities before they reach production.
- **Reduced attack surface:** modular architectures (for example, microservices) isolate components, preventing a single compromise from affecting the entire system.
- **Automated security controls:** IaC enforces security policies automatically, reducing human error.
- **Enhanced observability and threat detection:** well-architected applications have structured logging, monitoring, and telemetry for real-time security visibility.
- **Faster and safer incident response:** immutable infrastructure allows for rapid rollback in case of a breach.
- **Improved compliance and governance:** built-in security controls help meet compliance standards (NIST, ISO 27001, PCI-DSS, GDPR) from day one.
- **Resilience against supply chain attacks:** secure architectures verify software dependencies and container images (for example, using SBOM, sigstore, and attestation frameworks).
- **Scalability without compromising security:** secure design principles ensure that as applications scale, security remains consistent.

Copyright© 2025 PeopleCert International Ltd.

Architecture tradeoffs (1/2)

Architecture Tradeoff Analysis Method (ATAM)

- design choices based on tradeoff
- fit for purpose and fit for use
- each architecture can use a utility tree for an instance.

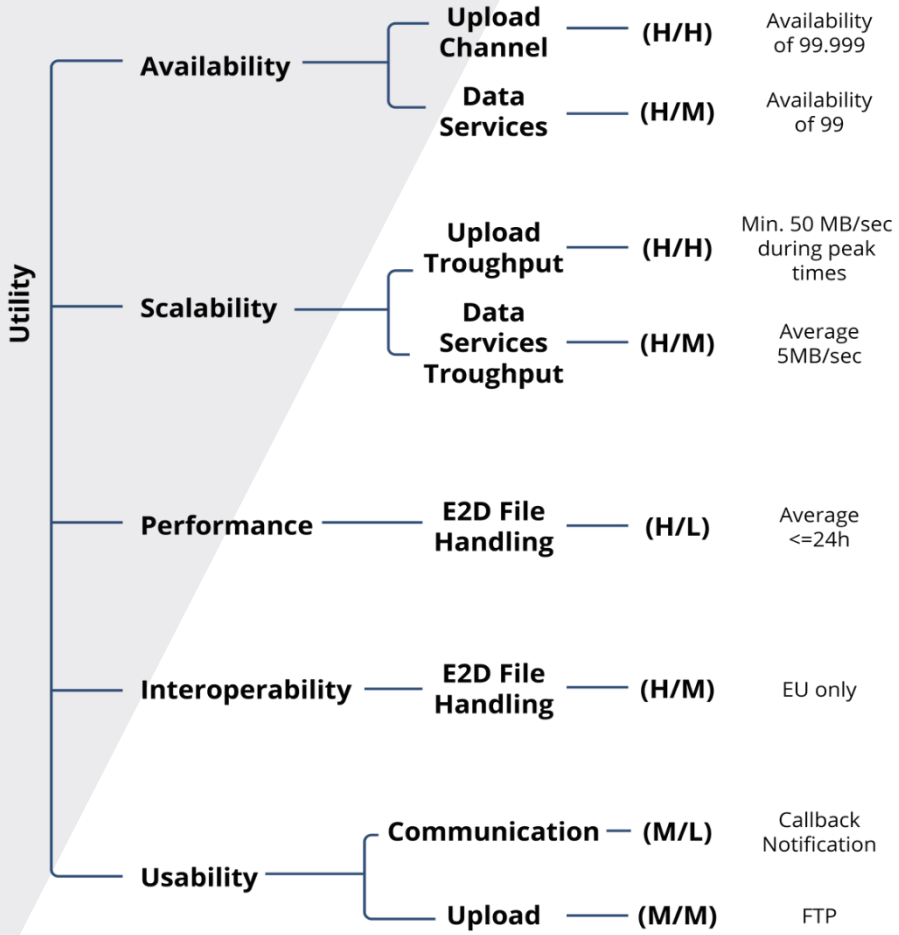
Filled utility trees

- Can be used to rapidly compare objects.

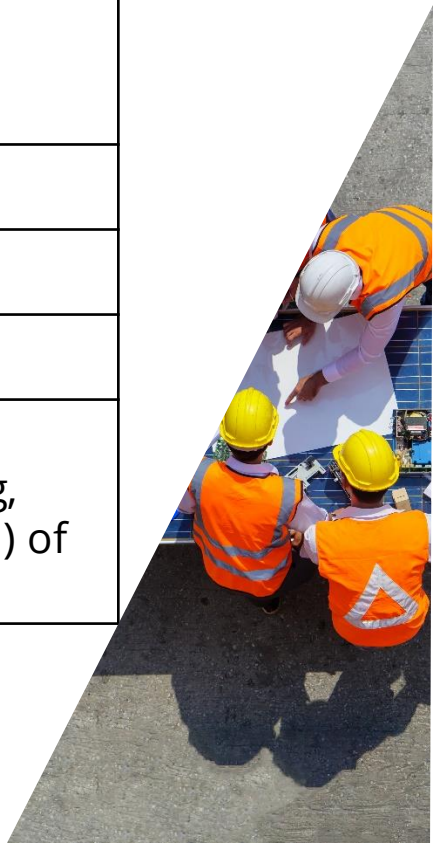


Copyright© 2025 PeopleCert International Ltd.

Architecture tradeoffs (2/2)



S3: Description	Data service(s) outage
Attribute	Availability
Business value/ architectural impact	Medium/Low
Stimulus	Outage
Environment	Data platform
Artifact	Data services
Response	Degraded user experience (UX) until service(s) is/are back up and running, with a Recovery Time Objective (RTO) of a maximum of 6 hours.



Copyright© 2025 PeopleCert International Ltd.

Event-driven architecture

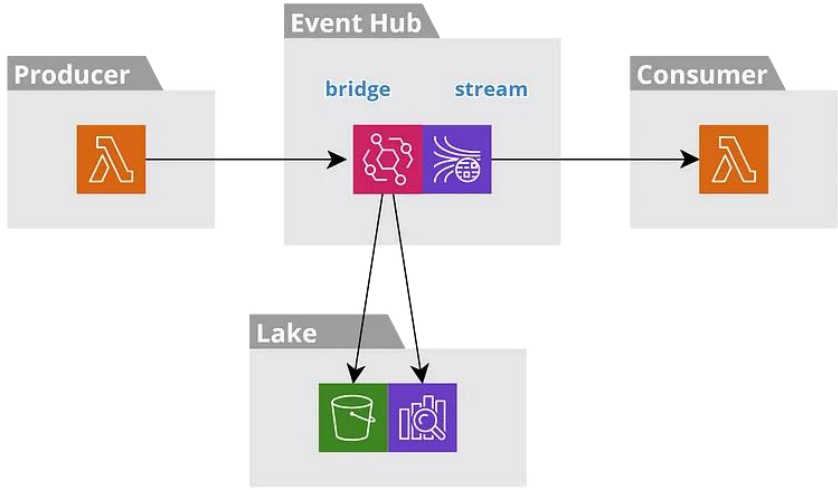
Desired state for software architecture

- Every element is tied to an event.
- An example is Function as a Service (FaaS).
- Pushes design decisions downstream.

SOLID principles: keys to good architecture

- **Single responsibility:** module responds to one actor.
- **Open-closed principle:** open for extension, closed for modification.
- **Liskov substitution:** objects are replaceable with subtypes, without altering correctness.
- **Interface segregation:** no client should depend on interfaces they do not use.
- **Dependency inversion:** module depends on abstractions not concretions.

Events are facts of system.



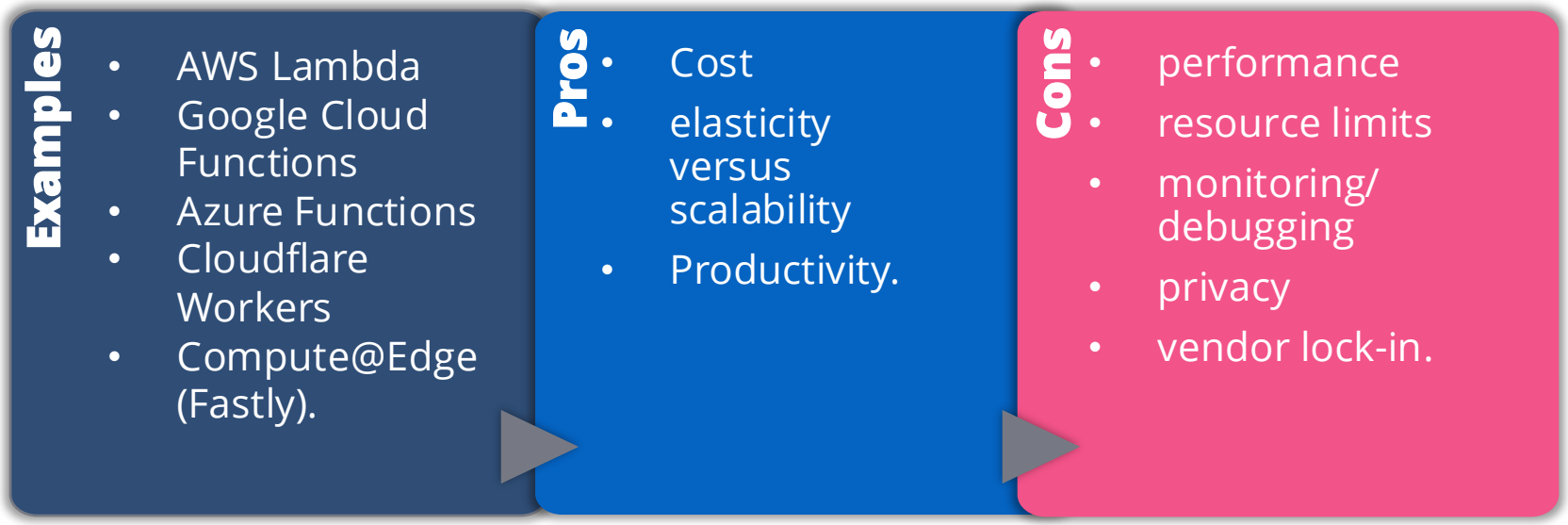
Source: https://medium.com/@jgilbert001/combining-the-best-of-aws-eventbridge-and-aws-kinesis-9b363b043ade

Copyright© 2025 PeopleCert International Ltd.

Serverless architecture (1/2)

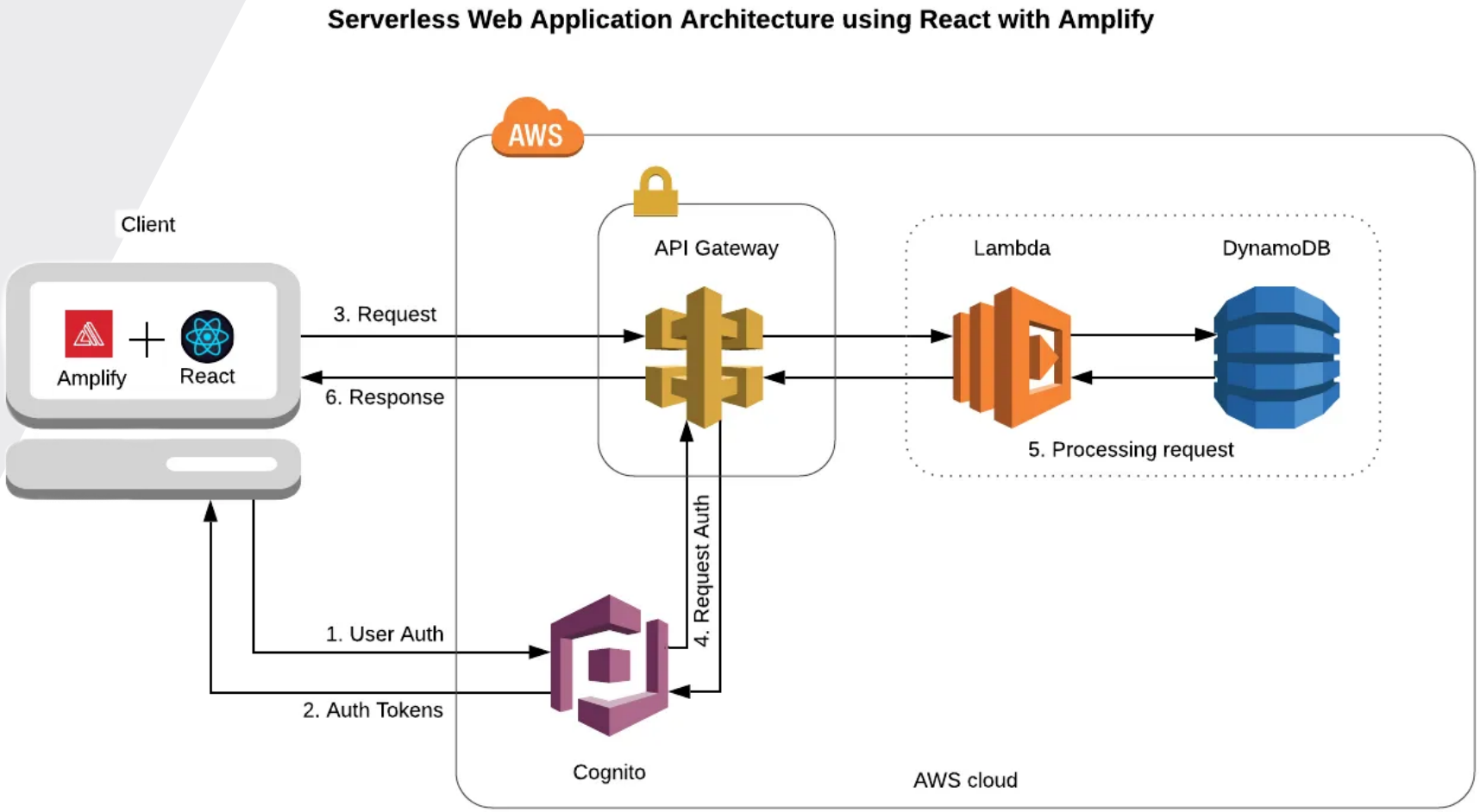
Cloud computing model, where resources are allocated on demand:

- servers centrally modified
- not owned by primary customary
- can accelerate code for DevOps
- backend between Event-driven architectures.



Copyright© 2025 PeopleCert International Ltd.

Serverless architecture (2/2)



Source: https://medium.com/zenofai/serverless-web-application-architecture-using-react-with-amplify-part1-5b4d89f384f7

Copyright© 2025 PeopleCert International Ltd.

Architecture metrics (1/2)

How do you measure architecture?

Performance metrics

- CPU: instructions per second.
- Graphics: pixels per second.
- I/O: transactions per second.
- Network performance: required bandwidth.

DevOps metrics

- MTTR
- Mean Time to Detect (MTTD)
- Deployment frequency
- Feature lead time.



Copyright© 2025 PeopleCert International Ltd.

Architecture metrics (2/2)

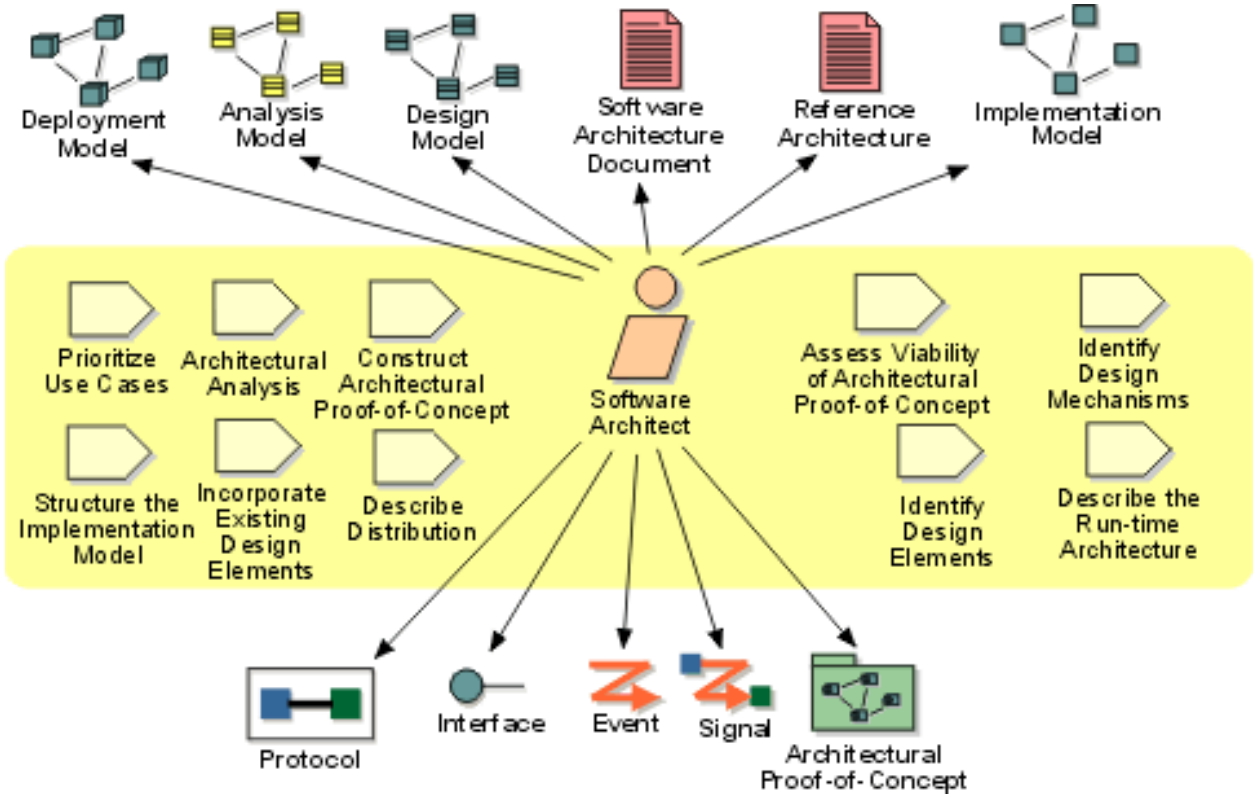
How do you measure architecture?

Cost metrics

- overall and incremented cost
- cloud time
- tied to performance.

Documentation metrics

- Does an architecture exist?
- Does it reflect needed actions?



Source: https://files.defcon.no/RUP/process/workers/wk_archt.htm

Copyright© 2025 PeopleCert International Ltd.